COLORADO
Information Security
Governor's Office of Information Technology

TS-CISO-002: Logging and Monitoring Standard

Document ID	TS-CISO-002
Title	Logging and Monitoring Standard
Executive Sponsor	Jill Fraser, Chief Information Security Officer
Issuing Authority	Governor's Office of Information Technology (OIT)
Applies to	All state government agencies, employees, contractors, vendors, and external users who access state government information systems and applications, regardless of location or device — on-premises, cloud, hosted, managed, and connected technologies — except where prohibited by privacy laws, or client systems designed to run on private devices owned by members of the public.
Instrument Type	Standard
Version	4.0
Effective Date	01/31/2026
Last Updated	07/09/2026

Purpose

This standard defines security requirements for logging and monitoring across all State information systems, infrastructure, applications, and endpoint devices, including workstations and servers, in both on-premises and cloud environments.

Scope

This standard applies to all state government agencies, employees, contractors, vendors, and external users who access state government information systems and applications, regardless of location or device. This includes on-premises, cloud, hosted, managed, and connected technologies, except where prohibited by privacy laws, or client systems designed to run on private devices owned by members of the public.

Requirements

The following requirements establish the minimum enterprise standards for logging and monitoring. Additional requirements must be implemented when required by regulated data types or applicable legal, regulatory, contractual, or policy obligations. Applicable additional requirements must be reflected in system security documentation, risk assessments, compliance artifacts, or other approved governance records.

Minimum Logging Requirements

System owners ensure that all applications, services, and infrastructure components generate security-relevant logs aligned with their technology type and documented risk profile. For purposes of this standard, risk profile must be determined using the organization's approved risk management process and documented through one or more of the following, as applicable:

- Logs must be protected against unauthorized access, modification, or deletion throughout the retention lifecycle, including during usage, transmission, storage, and disposal.
- Maintain logging integrity by enforcing default security events and capturing all configuration changes.
- Systems that generate logs must synchronize time with approved enterprise time sources where technically feasible to support event correlation and investigation.

The following system and application types must forward logs to the enterprise Security Information and Event Management (SIEM) system, where technically feasible and supported:

- Identity and Access Management (IAM) systems: directory services, single sign-on (SSO) platforms, multi-factor authentication (MFA) systems, and privileged access management (PAM) tools.
- Network infrastructure: firewalls, routers, switches, VPN gateways, proxies, and DNS servers.
- Endpoint systems: workstations, servers (physical and virtual), and endpoint detection and response (EDR) agents.
- Cloud platforms and services: cloud management consoles, infrastructure-as-a-service (IaaS) platforms, software-as-a-service (SaaS) applications that support log export, and container or orchestration platforms.
- Enterprise applications: state business systems, data management platforms, and any application that stores, processes, or transmits regulated or sensitive data.
- Security tooling: intrusion detection/prevention systems (IDS/IPS), web application firewalls (WAF), vulnerability scanners, and email security gateways.

Required Log Event Types

System owners must configure all enterprise assets to capture the following baseline event types to ensure audit integrity and traceability:

- Identity & Access: Successful/failed authentications, authorizations, session activity (logon/logoff), and account or privilege elevations.
- Administrative Actions: Execution of privileged commands, use of management tools, and resource provisioning/deprovisioning.
- Configuration Integrity: Changes to system security policies, rules, schemas, and system or application configurations.
- System Operations: Security tool execution, such as EDR/WAF alerts, critical process starts/stops, and application errors affecting availability.
- Data & Object Access: Access, modification, or deletion of sensitive data, regulated stores, and critical system objects.
- Validation & Defense: Input validation failures and network enforcement actions, including detections and blocks.

Required Log Metadata

At a minimum, application logs should include:

- Timestamp (ISO 8601)
- Service / application name
- Event type (e.g., error, transaction, performance, capacity)
- Severity or log level
- Descriptive message
- Correlation or request identifier (if available)

Log Retention Requirements

Logs generated under this standard must be retained to support security monitoring, incident response, forensic investigation, and compliance requirements. At a minimum:

- Online Storage: Logs must be retained in a readily accessible state for no less than 90 days.
- Archival Storage: Logs must be retained in an archived state for no less than one (1) year.
- Regulatory Compliance: Retention periods must be extended where required by regulatory, legal, contractual, or policy obligations, such as CJIS, IRS Publication 1075, HIPAA, or other applicable standards.

Continuous Monitoring Requirements

The Information Security Office and business owners are responsible for verifying that logging and monitoring controls stay effective over time. This is done through two types of log review — automated and manual — along with periodic assessments and regular reporting.

- Implement automated monitoring of audit logs to ensure real-time visibility into the security posture.
- Monitoring frequency and alert thresholds must be risk-adjusted based on the asset's impact level.
- Metrics must be reported to ensure the ongoing effectiveness of security controls.
- Monitoring and review procedures must define triage, escalation, and evidence retention expectations.
- Potentially malicious, unauthorized, or policy-violating activity must be investigated or escalated in accordance with incident response procedure.

1. Log Review

Logs must be reviewed on an ongoing basis to catch security issues, policy violations, and signs of unauthorized activity. Both automated and manual review are required.

Automated Review — runs continuously and is the primary method for detecting issues in real time; it does not replace manual review.

- The SIEM must ingest logs from all system and application types identified in the Minimum Logging Requirements section, and must be configured to automatically analyze those logs and generate alerts for suspicious or policy-violating activity.
- Alert rules and thresholds must be tuned based on the risk level of the system — higher-risk systems require more sensitive detection.

- Automated alerts must be routed to the appropriate security team for triage and response.
- Any system or application that cannot forward logs to the SIEM must be reviewed manually and documented as an exception to automated coverage.

Manual Review — security personnel must also review logs directly on a regular schedule, catching issues automated tools may miss.

- Critical and high-risk systems must be reviewed manually at least daily.
- Moderate-risk systems must be reviewed at least weekly.
- Low-risk systems must be reviewed at least monthly.

During each manual review, staff should check for:

- Unusual login attempts, access patterns, or privilege changes.
- Administrative or configuration changes that do not match an approved change record.
- Open alerts from automated tools that have not been addressed.
- Gaps in log data that could indicate a system failure or tampering.
- Unauthorized access to sensitive or regulated data.

Documenting and Escalating Findings:

- Each review must be logged with the date, what was reviewed, what was found, and what action was taken.
- Any finding that suggests malicious activity or a policy violation must be escalated to the Information Security Office and handled through the State's incident response process.
- Unresolved findings must be tracked and revisited at the next review cycle.

2. Periodic Assessments

Formal assessments must be conducted periodically to check whether the overall logging and monitoring program is working as intended — looking at coverage, configuration, and control effectiveness rather than individual events.

When Assessments Are Required:

- All in-scope systems must be assessed at least once per year.
- Systems handling regulated data (such as FTI, CJIS, HIPAA/ePHI, PCI, or SSA data) must also meet any additional assessment frequency required by the applicable regulation.
- An additional assessment must be completed after any major system change, migration, or security incident that affects logging.

What Assessments Cover:

- Are all required event types being captured?
- Are logs protected from tampering or unauthorized deletion?
- Are all systems synced to an approved time source?
- Are retention requirements being met?
- Are automated alerts working correctly and generating useful results?
- Are there any systems or areas not being logged or monitored?
- Is access to logging systems limited to authorized personnel?

Who Runs Assessments:

- The Information Security Office coordinates annual assessments and may bring in a qualified third party to assist.

- System owners must provide access and documentation and must resolve any issues found within timelines set by the Information Security Office.
- Assessment results must be documented and retained as compliance records in a secure location accessible to both the program and OIT Security Office.

3. Compliance Reporting

Compliance reporting is required and must be provided to the following:

- Agency security leads and OIT leadership: the Information Security Office is required to report on the status of logging and monitoring controls and any open issues.
- The CISO: the Information Security Office is required to report assessment findings and remediation status.
- Regulatory bodies and auditors: system owners are required to provide evidence of compliance when required by law or an applicable audit.

Recommendation

Monitoring Recommendations — the following recommendations may improve logging and monitoring effectiveness:

- Threat Intelligence Integration: Integrate relevant threat intelligence to improve detection and prioritization of known malicious activity.
- User and Entity Behavior Analytics: Consider behavior analytics where warranted to identify unusual activity that may indicate compromised accounts or insider threat.
- Regular Security Assessments: Periodically assess logging coverage, alert fidelity, and control effectiveness, and address identified gaps.

Exceptions

All exceptions must be documented, justified, and approved by the organization's Chief Information Security Officer (CISO) or other designated authority. Compensating controls must be documented, implemented, and maintained.

Compliance

The Information Security Office will monitor and advise on compliance with this standard.

Additional Compliance Requirements

The requirements defined within this standard establish the minimum enterprise logging and monitoring baseline applicable to all State of Colorado information systems.

Systems that process, store, transmit, or provide access to regulated, confidential, or contractually restricted data must implement any additional logging, monitoring, retention, review, or audit requirements required by applicable legal, regulatory, contractual, or program-specific obligations. These additional requirements are defined in the Logging and Monitoring Compliance Attributes document, which serves as the authoritative reference for data-type-specific logging requirements, including but not limited to:

- IRS Federal Tax Information (FTI)
- Payment Card Industry (PCI)
- Criminal Justice Information (CJI/CJIS)
- Social Security Administration (SSA) data

- HIPAA/ePHI
- Personally Identifiable Information (PII)
- ARC-AMPE and successor federal program requirements

Where multiple requirements apply, systems must implement the most restrictive applicable logging, monitoring, retention, and review requirements unless formally documented otherwise through an approved risk exception process. Applicable requirements must be documented within system security plans, architectural documentation, compliance artifacts, risk assessments, or other approved governance records.

References

- Logging and Monitoring Compliance Attributes